

Malicious Code and Defences

IS 2204 - Information Systems Security

Dilanga Harshani

University of Colombo School of Computing

July 24, 2026

Where You Are

- Introduction to Information Security and CIA Triad
- Symmetric and Asymmetric Cryptography
- Email and Document Security
- Transport Layer Security
- Payment Security and Blockchain
- Network Security Protocols
- **Systems Security : Malware and Defences**

Today's Roadmap

- **Malicious Code**

How it spreads, what it does and what form it takes

- **Firewalls**

The perimeter that filters traffic before it reaches your systems

- **Intrusion Detection Systems**

Catching what the perimeter alone could not stop

What is Malware?

- Software inserted into a system, typically covertly, to compromise confidentiality, integrity, or availability
- A single umbrella term covering a wide range of distinct mechanisms and intentions

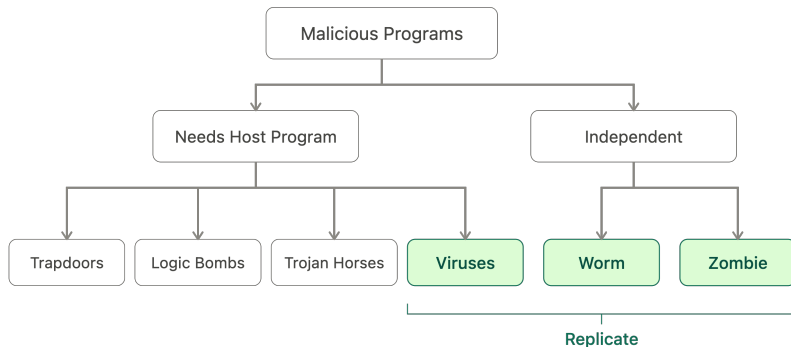
Advanced Persistent Threat (APT)

- A well-resourced adversary conducting a sustained, targeted campaign against a specific organisation
- Prioritises stealth and persistence over speed
- Malware is often just one tool within a much longer campaign, not a standalone event

Classifying Malware : Two Independent Questions

- **How does it spread?** Propagation Mechanism
- **What does it do once there?** Payload
- These two questions are independent, the same payload can travel via different propagation mechanisms, and vice versa

Older Classification of Malware

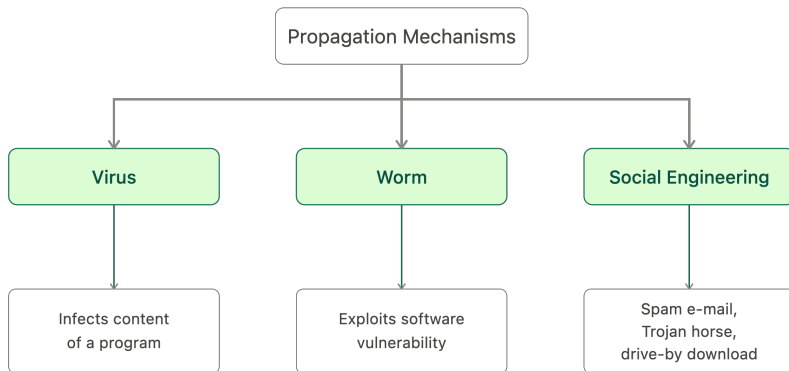


New Classification of Malware

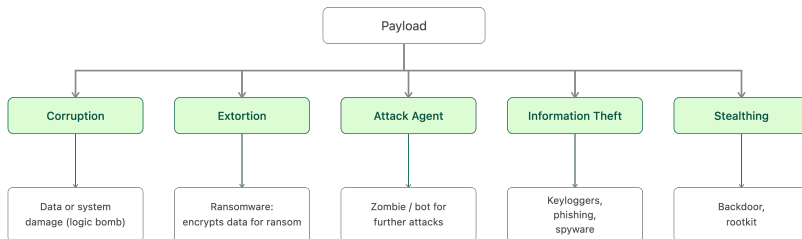
Payload	Propagation Mechanism		
	Virus	Worm	Social Engineering
	Corruption		
	Extortion		
	Attack Agent		
	Information Theft		
	Stealth		

Any propagation mechanism can carry any payload type

New Classification of Malware : Propagation Mechanisms



New Classification of Malware : Payload



Propagation : Viruses

- Infects existing content, inserts itself into other programs or files
- Requires a human to run the infected program before it can spread further
- Lifecycle : dormant $\rightarrow$ propagation $\rightarrow$ triggering $\rightarrow$ execution

How Viruses Attach

- Appended to the host program
- Surrounds the host program
- Integrated into the host program's own code
- Replaces the host program entirely

Signatures and Evading Detection

- A virus's code existing somewhere in a computer and its behaviour form a recognisable, describable pattern which is known as a **signature**
- Virus scanners search files and memory for known signatures
- **Polymorphic viruses** change their own form on every copy, specifically to defeat signature matching
- **Macro viruses** are interpreted rather than directly executed, riding inside document macros, independent of machine architecture

Propagation : Worms

- Exploits a vulnerability to spread and requires no human action
- Does not need to infect a host file, the worm itself is the complete program
- Case study : The Morris Worm (1988) disabled thousands of UNIX systems within hours, directly led to the creation of CERTs

Propagation : Social Engineering

- **Trojan Horse** : Malicious code hidden inside an apparently useful program; does not replicate
- Relies on convincing a human to bypass their own security judgement (e.g. opening an unsolicited attachment or PDF)
- The delivery method here is deception, not a technical exploit

What Qualities Do Malware Authors Want?

- Hard to detect
 - Difficult to destroy or deactivate
 - Spreads widely
 - Capable of reinfection
 - Easy to create
 - Machine and OS independent
-
- Very few examples of malware achieve all of these qualities simultaneously

Payload : System Corruption

- **Logic bomb** : Dormant code that triggers on a specific condition, then damages the system
- Example : Code that deletes payroll records if a specific employee's own record is ever deleted
- **Rabbit (bacteria)** : A program that absorbs all of some class of system resource, without infecting or spreading
- Example : A simple loop repeatedly creating directories, exhausting disk space or inode capacity

Payload : Cryptoviral Extortion (Ransomware)

- Malware embeds a public key, encrypts the victim's data using a freshly generated key, then encrypts that key with the embedded public key
- Only the attacker's private key can recover the data, this is the basis of the ransom demand
- Some variants further hide their true purpose from analysts using environment-dependent decryption keys (e.g. derived from the target's own files or network context)

Payload : Attack Agents

- **Zombie / Bot** : A compromised machine secretly controlled to launch attacks on the attacker's behalf
- A network of such machines under common control is a **botnet**
- Commonly used to launch distributed denial-of-service (DDoS) attacks

Payload : Information Theft

- **Keyloggers** : Capture keystrokes to harvest credentials
- **Phishing** : Deceptive communication designed to trick a user into revealing sensitive information
- **Spyware** : Monitors user activity and exfiltrates data without consent

Payload : Stealthing

- **Backdoor (trapdoor)** : A secret entry point bypassing normal security checks, often left in place by a developer
- **Rootkit** : A set of tools that conceals the presence of malware and maintains privileged access, often at the operating system level

Anti-Virus Technologies

- **Signature-based scanning** matches files against a library of known patterns
- **Heuristic detection** flags code structures associated with malicious behaviour
- **Emulation** runs suspicious code in a safe, simulated environment to force it to reveal its true behaviour

Modern Malware Analysis

- **Static analysis** examines the file without running it (hashes, embedded strings/URLs)
- **Dynamic analysis** executes in an isolated sandbox and observe behaviour
- **Memory forensics** inspect running memory for hidden or injected code
- **Threat intelligence** cross-references findings against shared databases (e.g. VirusTotal, MITRE ATT&CK)

Malware Analysis Tools

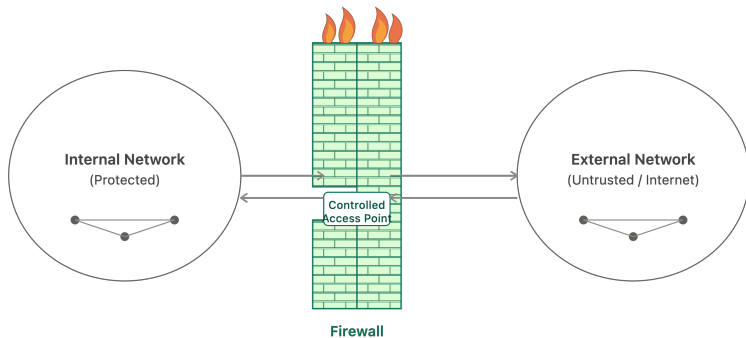
- **VirusTotal** : Free service cross-referencing a file or URL against dozens of scanning engines simultaneously
- **ANY.RUN** : Interactive online sandbox for dynamic analysis, observing malware behaviour in near real time
- **Hybrid Analysis** : Free community service combining static and dynamic analysis in one submission

Intruder Information Gathering Techniques

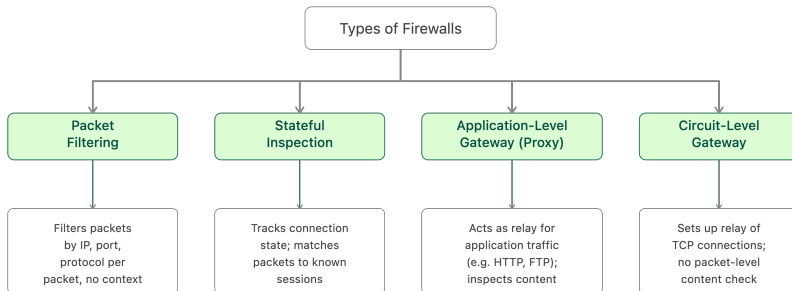
- System logs
- Firewall and network traffic logs
- Intrusion detection systems
- Honeytokens, honeypots, and honeynets

What is a Firewall?

- A control point between a trusted network and an untrusted network

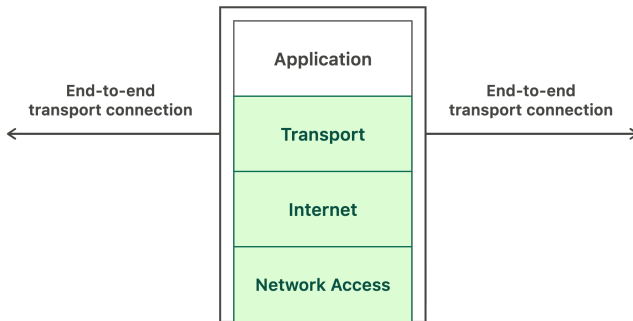


Types of Firewalls



Packet Filtering Firewall

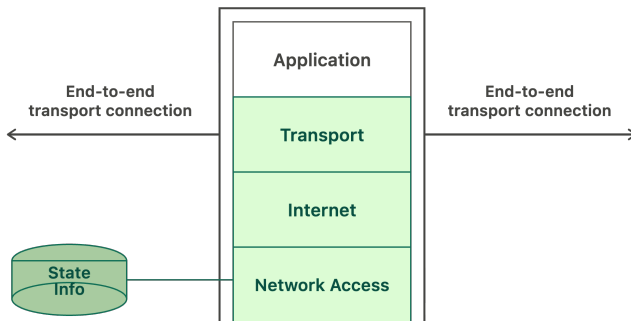
- Simplest form is a **packet filter** which inspects each packet in isolation against a fixed rule set
- Limitation : no memory of prior packets, so it cannot judge whether a packet belongs to a legitimate, ongoing conversation



Packet Filtering Firewall

Stateful Inspection Firewall

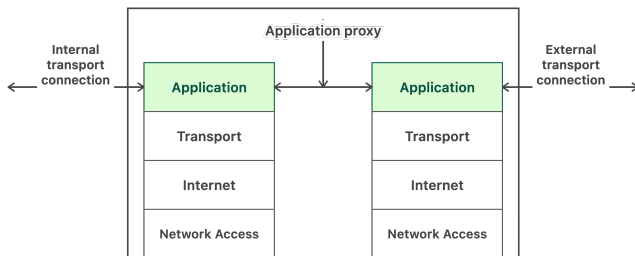
- Tracks active connections and checks that each packet validly belongs to one
- Detects bogus, out-of-context packets that a stateless filter would miss



Stateful Inspection Firewall

Application-Level Gateway (Proxy)

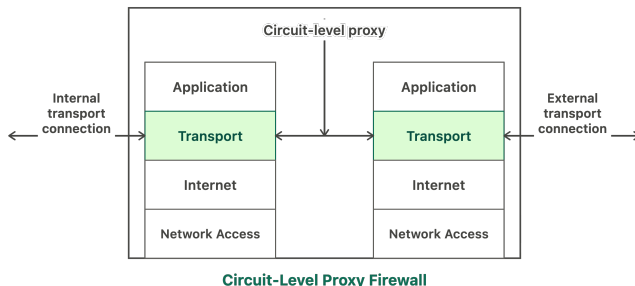
- Has full visibility into the application protocol itself, not just packet headers
- Validates the request, then forwards it and relays the response
- Requires a separate proxy per protocol supported



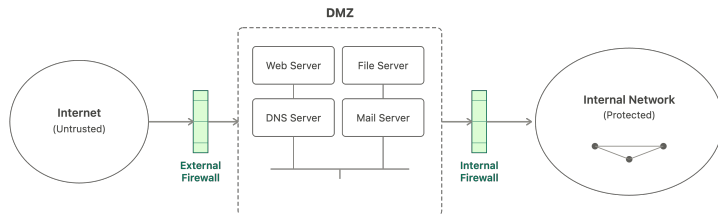
Application Proxy Firewall

Circuit-Level Gateway

- Relays two TCP connections, validating only at connection setup
- Once established, passes traffic through without inspecting contents



Demilitarized Zone & Virtual Private Networks



- **Demilitarized Zone (DMZ)** : A separate subnetwork hosting the limited services outsiders need to reach, kept apart from the internal network
- **Virtual Private Networks (VPN)** : A private, protected connection carried over a public network (tunnel)
- Modern firewall products bundle both alongside content filtering

Problems With Firewalls

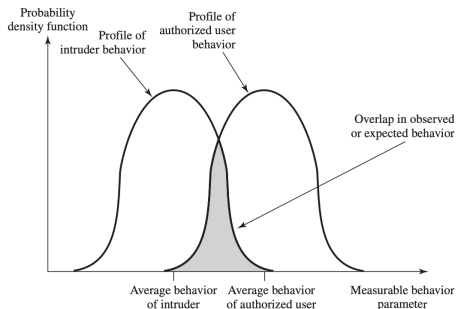
- Can block legitimate services and complicate diagnostics
- Filtering by domain does not stop attacks using raw IP addresses directly
- No content inspection : If a service is allowed through, malicious content riding on that service is allowed through too
- **Encrypted traffic cannot be inspected at all**, a fundamental limitation, not a configuration gap

Intrusion Detection System (IDS)

- Identifies and responds to malicious activity targeting a system's resources
- Assumes no system or policy is ever 100% secure, monitors behaviour rather than relying purely on prevention

Signature-Based vs Anomaly-Based Detection

- **Signature-based** : Matches known attack patterns, requires frequent updates, misses novel attacks
- **Anomaly-based** : Flags deviation from an established baseline of normal behaviour, risks false alarms when normal behaviour itself varies



Passive vs Active Response

- **Intrusion Detection Systems (IDS)** are passive. It generates an alert and a human decides what to do
- **Intrusion Prevention Systems (IPS)** are active. Takes automatic action, drops a session, blocks an IP, locks an account
- Automatic action raises the stakes of a false positive

Effectiveness

		Reality	
		Actual Intrusion	Actual Normal
Detection Result	Flagged as Intrusion	True Positive Intrusion correctly detected	False Positive False alarm on normal activity <i>(costly, but safe)</i>
	Flagged as Normal	False Negative Intrusion missed, flagged as normal <i>(dangerous)</i>	True Negative Normal activity correctly ignored

- Minimizing false negatives (missed intrusions) often increases false positives (false alarms), and vice versa
- Every real system trades off somewhere between the two

Honeypots, Honeytokens, Honeynets

- **Honeypot** : A decoy system deployed to attract, detect, and study attackers without risking genuine assets
- **Honeytoken** : A single decoy piece of data (e.g. a fake credential) that triggers an alert if ever used
- **Honeynet** : A network of honeypots, simulating a more realistic target environment

Summary

- **Malware** : Classified based on how it spreads (propagation) and what it does (payload). Any propagation can carry any payload
- **Propagation** : Viruses (need a host, need a human), worms (self-contained, no human needed), social engineering
- **Payload** : Corruption, extortion, attack agents, information theft, and stealthing
- **Firewalls** : Filter traffic at the perimeter, packet filtering, stateful inspection, proxies, and circuit-level gateways
- **Intrusion Detection** : Catches what the perimeter cannot, signature vs anomaly-based, passive vs active
- All trying to answer the same underlying question, **how do we protect a system that can never be made perfectly secure?**

Any Questions?